

**Tempo a disposizione per l'esame: 1:30 h**

Rispondere brevemente ma in modo completo alle seguenti domande.

1. In che cosa consiste un attacco di tipo *SQL injection* e quali condizioni devono essere soddisfatte a lato client e a lato server perchè sia possibile un tale attacco? Quali sono delle contromisure efficaci?
2. Spiegare cosa significa garantire la sicurezza in termini di *proprietà di sicurezza* di un sistema. Nella risposta discutere se i termini *confidenzialità*, *privacy* e *anonimato* siano sinonimi o meno.
3. Dire cosa si intende per *certificato digitale*, a cosa serve, come venga creato e utilizzato.
4. Si consideri il seguente output del comando `ls -l`:

```
-rwxr----- 1 alice studenti 1250 mag 20 10:15 report.txt
```

Spiegare il significato dei permessi associati al file, indicando quali operazioni possono essere eseguite dal proprietario, dagli utenti appartenenti al gruppo `studenti` e dagli altri utenti del sistema. Descrivere inoltre il significato dei privilegi *setuid* e *setgid*.

5. In Apache, che tipo di regole si possono scrivere utilizzando le direttive *user-based*?
6. In che cosa consiste un attacco di tipo *Reflected XSS*? Quali sono le possibili contromisure?
7. Descrivere uno dei protocolli “di base” di tipo *challenge-response* per l'autenticazione visti a lezione (è indifferente l'uso di *nonce* o di *timestamp*) e spiegare :
  - Perché il protocollo non può subire un *replay attack*;
  - Come si deve modificare il protocollo in modo che si ottenga *mutua autenticazione*.